honorapp — Respaldo y recuperación

Oct 16, 2026 · @Grafica Dnews

Prioridades y estimación

Los cinco puntos van antes de que entren datos reales; en total son entre 39 y 56 horas, ordenadas por cuánto daño evita cada una si falta.

Prioridad	Punto	Horas	Por qué en este orden
1	Backups automáticos	8–11	Una pérdida de datos sin backup es irreversible
2	Recuperación de contraseña	8–11	Sin esto, un usuario que olvida la contraseña pierde el acceso a sus datos
3	Plan ante fallas y simulacro	5–8	Un backup que nunca se restauró no garantiza nada
4	Borrado por error	10–14	Gran parte ya está cubierta por las anulaciones del modelo; falta deshacer, papelera e importaciones
5	Export completo	8–12	Obligatorio para el derecho de acceso y antes de borrar cuentas, pero no evita pérdidas

Las horas suponen una persona que ya conoce Supabase y Next.js, e incluyen pruebas. No incluyen el diseño visual de las pantallas.

Costo mensual del esquema propuesto: plan Pro de Supabase desde US$25 (incluye US$10 de crédito de cómputo) más el almacenamiento externo de los backups, que para una base de este tamaño debería ser de centavos. *El costo del almacenamiento externo es una estimación, no lo verifiqué.*

Backups automáticos

Dos capas independientes: los backups diarios de Supabase Pro para restaurar rápido, y una copia propia cifrada cada 6 horas fuera de Supabase para cuando el problema es Supabase o la cuenta.

Capa	Frecuencia	Retención	Dónde	Restauración	Costo
Backups diarios de Supabase	Diaria	7 días	Supabase, misma región del proyecto	Desde el panel, sobre el mismo proyecto. El proyecto queda inaccesible mientras dura	Incluido en Pro (desde US$25/mes)
Copia externa propia	Cada 6 horas	7 días las de 6 horas; 30 días una diaria	Bucket de almacenamiento de objetos externo, cifrado	Descifrar y cargar en un proyecto nuevo de Supabase	Centavos por mes *(estimado)*
Recuperación a un punto en el tiempo (PITR)	Continua, al segundo	7, 14 o 28 días	Supabase	Desde el panel, eligiendo fecha y hora	~US$100/mes por 7 días, más un cómputo mayor obligatorio

Decisión: sin PITR en v1. Para una app gratuita, ~US$100 por mes más el cómputo extra no se justifica al principio. La copia cada 6 horas baja la pérdida máxima de 24 a 6 horas por casi nada. Revisar cuando haya muchos usuarios activos.

El plan gratuito no sirve para datos reales. No tiene backups automáticos y pausa el proyecto tras una semana sin actividad.

Cómo es la copia externa

1. Un workflow programado de GitHub Actions corre cada 6 horas.
2. Ejecuta `supabase db dump` tres veces: roles, esquema y datos.
3. Comprime y cifra el resultado con `age`, usando una clave pública guardada en el workflow. La clave privada nunca está en GitHub: queda guardada offline en dos lugares distintos.
4. Sube el archivo cifrado a un bucket compatible con S3 (por ejemplo Backblaze B2, Cloudflare R2 o AWS S3).
5. Las credenciales del bucket en GitHub solo permiten escribir: no pueden leer ni borrar. Si alguien roba esos secretos, no puede llevarse ni destruir los backups.
6. El bucket tiene bloqueo de objetos y reglas de vencimiento que aplican la retención sola.

Por qué no en el repo de GitHub, como sugiere la guía de Supabase

La guía oficial guarda los dumps en un repo privado. Para honorapp es mala idea: el historial de git guarda cada versión para siempre, así que un paciente suprimido seguiría ahí indefinidamente, y cualquiera con acceso al repo ve todos los datos.

Supresión y backups

- Los backups conservan datos suprimidos hasta que vencen: como máximo 30 días. La política de privacidad tiene que decirlo.
- Se agrega una tabla `supresiones` que guarda solo el `id` y la fecha de cada paciente suprimido, sin datos personales. Después de cualquier restauración se vuelve a aplicar `suprimir_paciente` sobre esos ids.

Dónde quedan las copias: la región del bucket es una transferencia de datos más. Tiene que seguir la misma decisión legal que la base (ver la revisión de seguridad).

Pendiente de verificar: si `supabase db dump` incluye los usuarios de `auth.users`. Si no los incluye, restaurar en un proyecto nuevo obliga a todos a recuperar la contraseña. Se confirma en el primer simulacro.

Export completo para el usuario

Un botón "Descargar todos mis datos" genera en el navegador un ZIP con todo lo del profesional, legible en Excel y reimportable por máquina, sin que el archivo quede guardado en ningún servidor.

Contenido del ZIP

Archivo	Para qué	Contenido
`honorapp-AAAA-MM-DD.xlsx`	Leerlo en Excel	Una hoja por tema: pacientes, aranceles, agendas, sesiones, a cobrar, pagos, aplicaciones de pagos, ajustes, cotizaciones
`csv/*.csv`	Abrirlo en cualquier programa	Un CSV por tabla, UTF-8 con BOM para que Excel muestre bien los acentos
`honorapp.json`	Portabilidad y reimportación	Todo, con `version_esquema` y fecha de generación
`LEEME.txt`	Entender el archivo	Qué es cada archivo, qué significa cada estado y aviso de que contiene datos sensibles

Reglas

- Incluye todo, también lo anulado y lo archivado, con su estado y fecha. Si se excluyera, el export no serviría como respaldo.
- No incluye la auditoría ni datos técnicos internos.

- Montos como números, con la columna `moneda` aparte. Fechas en formato `AAAA-MM-DD`.
- Toda celda de texto que empiece con `=`, `+`, `-` o `@` se escapa, para que un nombre no ejecute una fórmula en Excel.
- Opción "Exportar con iniciales", igual que en el export mensual.

Cómo se arma

1. Una RPC `exportar_todo()` (con `security invoker`, así respeta RLS) devuelve los datos del usuario en JSON, paginada por tabla si la cuenta es grande.
2. El navegador arma el XLSX, los CSV y el ZIP, y lo descarga.
3. Se registra en la auditoría que hubo un export, sin su contenido.

Usos del mismo mecanismo

- Derecho de acceso de un paciente: la misma función filtrada por `paciente_id`.
- Antes de borrar una cuenta, la pantalla ofrece descargarlo y se respeta un período de gracia de 30 días.
- Copia propia del profesional: la app sugiere descargarlo una vez por mes.

Fuera de v1: importar un `honorapp.json` para restaurar una cuenta o mudarla. El formato se define desde ahora con `version_esquema` para que sea posible después.

Recuperación de contraseña

Supabase ya responde igual exista o no el email; lo que falta es que la interfaz, el email y los límites no lo delaten, y que recuperar la contraseña no saltee el MFA.

Flujo

1. **Pedido** (página pública): el usuario escribe su email y resuelve el CAPTCHA. Se llama a `resetPasswordForEmail` con `redirectTo` a la página de cambio.
2. **Respuesta en pantalla, siempre la misma:** "Si hay una cuenta con ese email, te enviamos un enlace. Revisá también el correo no deseado." Sin importar si el email existe, ni si hubo un error de envío.
3. **Email** en español, desde el dominio propio: el enlace, cuánto dura y "Si no lo pediste, ignorá este mensaje; tu contraseña no cambió". Sin datos de pacientes.
4. **Página de cambio** (solo con la sesión de recuperación): nueva contraseña con las mismas reglas que el registro (12 caracteres mínimo, chequeo de filtradas).
5. **Al guardar:** se cierran todas las demás sesiones abiertas y se envía un email de aviso "Tu contraseña cambió".

6. **Si tiene MFA:** la sesión de recuperación es de nivel `aal1`, así que la política restrictiva de RLS no le muestra datos hasta que valide el segundo factor. Recuperar la contraseña no permite saltear el MFA.

Para no revelar si un email está registrado

Punto de fuga	Cómo se cierra
Mensaje de la pantalla de recuperación	Siempre el mismo texto (paso 2)
Respuesta de Supabase	Ya devuelve éxito aunque el email no exista, sin enviar nada
Registro con un email ya usado	Mensaje genérico "Revisá tu correo para continuar". *Verificar que Supabase no devuelva un error distinto con la confirmación de email activada*
Inicio de sesión	"Email o contraseña incorrectos", sin distinguir
Tiempo de respuesta	*Posible diferencia si el envío del email demora la respuesta. Verificar midiendo; si se nota, responder siempre después del mismo tiempo*

Configuración

- SMTP propio: el integrado permite solo 2 emails por hora, inviable para recuperos reales.
- URL de redirección: solo la de producción en la lista permitida del proyecto de producción. Sin comodines para deploys de preview.
- Vigencia del enlace: 1 hora como máximo y de un solo uso. *Verificar el valor configurado en el proyecto.*
- Límite: el de Supabase (un pedido cada 60 segundos por usuario, más los límites por IP) más el CAPTCHA.

Si pierde el dispositivo de MFA y la contraseña

No se automatiza. Proceso manual por email con verificación de identidad: por ejemplo, una pregunta sobre datos que solo el profesional conoce (cantidad de pacientes, fecha del último cobro). Se documenta cada caso en la auditoría.

Borrado por error

Desde la interfaz nada se borra físicamente: todo se anula o se archiva, así que cada error del usuario se deshace dentro de la app sin tocar los backups. La única acción irreversible es la supresión de un paciente.

Qué borró por error	Mecanismo	Cómo vuelve atrás	Plazo
Un pago, una sesión o un ajuste	Anulación (ya en el modelo)	Aviso "Pago anulado · Deshacer" durante 10 segundos; después, desde la papelera	Siempre
Un paciente	Archivado (`archivado_at`)	"Pacientes archivados" → Restaurar	Siempre
Una importación entera mal hecha	Anulación en bloque por `importacion_id`	"Deshacer importación" en el historial de importaciones	7 días
Un cambio en un dato (concepto, nota, referencia)	Auditoría	"Historial" del registro, con restaurar el valor anterior	Siempre
Teléfono, email o nombre de un paciente	No se guarda el valor anterior (decisión de privacidad)	No se puede: hay que volver a cargarlo	—
Un paciente suprimido	Supresión	No se puede, a propósito. Doble confirmación escribiendo el nombre	—
Su cuenta entera	Borrado programado	Volver a iniciar sesión cancela el borrado	30 días

Papelera

- Una pantalla "Papelera" lista lo anulado o archivado en los últimos 30 días: pagos, sesiones, ajustes y pacientes.
- "Restaurar" un pago o una sesión anulados crea uno nuevo idéntico con `reemplaza_a` apuntando al anulado, y se vuelve a aplicar FIFO. Es coherente con la regla del modelo de que un anulado no se reactiva.
- Restaurar un paciente archivado solo borra `archivado_at`.
- Después de 30 días lo anulado no desaparece: sigue en la base y en los exports, solo deja de aparecer en la papelera.

Nuevas RPCs: `restaurar_pago`, `restaurar_prestacion`, `restaurar_paciente` y `deshacer_importacion`. Las cuatro registran auditoría y aplican las mismas validaciones que la creación.

Lo que no se hace: restaurar un backup por el error de un usuario. Restaurar la base completa pisaría los datos de todos los demás profesionales. Si un caso no se resuelve desde la app, se descifra la copia externa en un proyecto temporal, se extraen solo las filas de ese `owner_id` y se reinsertan con un script revisado. Es un proceso manual de excepción.

Plan ante fallas de la base

Objetivo: perder como máximo 6 horas de datos y volver a estar en línea en menos de 4 horas en el peor caso razonable. Los tiempos son estimaciones para una base chica y hay que confirmarlos en el primer simulacro.

Escenarios

Escenario	Cómo se detecta	Qué se hace	Datos perdidos	Tiempo estimado
Supabase caído (falla del proveedor)	Errores en la app; página de estado de Supabase	Modo mantenimiento con aviso y esperar. No restaurar nada	Ninguno	Lo que tarde el proveedor
Datos dañados por un bug o una migración mala	Saldos imposibles, errores en vistas, quejas de usuarios	Pasos 1 a 9 con el backup diario de Supabase o la copia externa, el que sea más reciente y anterior al daño	Hasta 24 h (diario) o hasta 6 h (copia externa)	2 a 4 h
Proyecto o cuenta de Supabase perdidos o comprometidos	Sin acceso al panel, cambios que nadie hizo	Proyecto nuevo, restaurar la copia externa, rotar todas las claves, reconfigurar Auth	Hasta 6 h	4 a 8 h

Escenario	Cómo se detecta	Qué se hace	Datos perdidos	Tiempo estimado
Acceso indebido a datos	Alertas, auditoría, aviso de un usuario	Plan de incidentes de la revisión de seguridad; restaurar solo si hubo alteración	Depende	Depende

Pasos ante datos dañados

1. **Contener (10 min):** activar el modo mantenimiento, una variable en Vercel que muestra un aviso y bloquea escrituras. Así no se siguen generando datos sobre una base dañada.
2. **Delimitar (20–40 min):** con la auditoría y los logs, determinar desde cuándo hay datos dañados y si afecta a todos o a algunos usuarios. Si afecta a uno solo, usar el proceso manual por `owner_id` de la sección anterior.
3. **Elegir el punto de restauración (10 min):** el backup más reciente anterior al daño. Anotar qué ventana de datos se pierde.
4. **Restaurar (30–90 min):** backup diario desde el panel de Supabase, o copia externa descifrada en un proyecto nuevo y cambio de las variables de entorno en Vercel.
5. **Reaplicar supresiones (10 min):** correr `suprimir_paciente` sobre los ids de la tabla `supresiones`.
6. **Verificar (30 min):** conteos por tabla contra lo esperado, tests de aislamiento entre usuarios, inicio de sesión con una cuenta de prueba, una operación de pago de punta a punta.
7. **Reabrir:** desactivar el modo mantenimiento.
8. **Avisar a los usuarios:** email explicando qué ventana horaria se perdió, para que vuelvan a cargar lo de ese período desde sus propios registros.
9. **Revisión posterior (1–2 h, al día siguiente):** causa, qué falló en la detección, qué cambia para que no se repita.

Si se restaura en un proyecto nuevo, además:

- Volver a configurar Auth: SMTP, URL de redirección, CAPTCHA, reglas de contraseña y sesiones. Conviene tenerlo anotado en el repo, porque esto no viaja con el dump.
- Rotar las claves y actualizar Vercel y los secretos del workflow de backups.
- Si `auth.users` no viaja con el dump, todos los usuarios tienen que recuperar la contraseña (pendiente de verificar en el simulacro).

Simulacro

Antes del lanzamiento y después cada tres meses: restaurar la última copia externa en un proyecto de prueba, medir cuánto tarda cada paso y actualizar los tiempos de esta tabla. Un backup que nunca se restauró no está probado.

Fuentes

Consultadas el 16/10/2026.

- Database backups — Supabase
- Pricing — Supabase
- Automated backups using GitHub Actions — Supabase
- Password-based auth — Supabase